

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

GRC102: INFORMATION SECURITY GOVERNANCE

Week 2 Practical Laboratory

Developing Security Policies and Procedures

Student Name: Imelda Sanya

Registration Number: C11/26/CGRCE/17576

Evidence Bundle 1 — Policy Hierarchy and Categorisation

The old “IT Rules” document mixes policy intent, technical instructions and recommendations. I separated these into four document types so that mandatory requirements are clear and technical steps sit in procedures where appropriate.

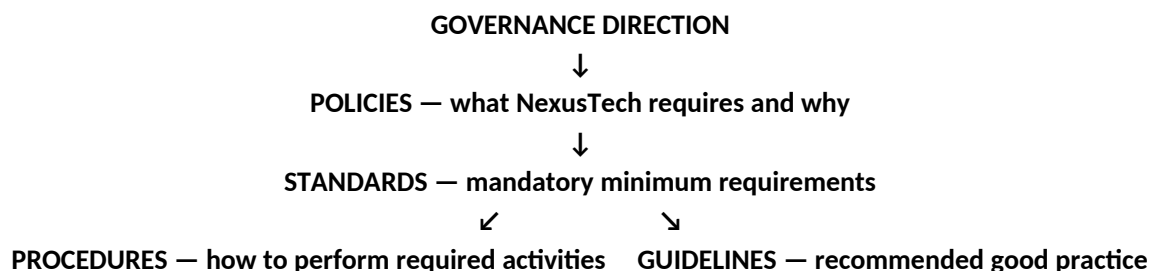
1.1 Hierarchy Definition Table

Document type	Purpose	Authority	Mandatory / recommended	Level of detail
Policy	Sets the organisation's direction, intent and rules for information security.	Approved by the appropriate executive authority.	Mandatory.	High-level; states what must or must not happen.
Standard	Defines mandatory minimum requirements that support a policy.	Approved by the relevant security/governance authority.	Mandatory.	More specific than policy; defines measurable minimum requirements.
Procedure	Explains how an approved requirement is carried out consistently.	Owned by the responsible operational function and approved through the policy framework.	Mandatory when the related policy/standard requires the activity.	Detailed, sequential and action-oriented.
Guideline	Provides practical advice where flexibility is acceptable.	Issued or maintained by the responsible function.	Recommended unless another document makes it mandatory.	Practical advice with more flexibility than a standard.

1.2 Classification of the Eight Statements

#	Statement summary	Classification	Justification
1	Remote corporate network access requires MFA.	Standard	It sets a mandatory minimum authentication requirement rather than explaining how to configure it.
2	Steps for configuring MFA with the Authenticator app.	Procedure	It gives specific step-by-step instructions for completing an activity.
3	Developers are recommended to use parameterised queries.	Guideline	The wording is recommended and gives good practice advice rather than a mandatory minimum.
4	Commitment to confidentiality, integrity and availability of client data.	Policy	It expresses a high-level security commitment and direction.
5	Corporate laptops must use BitLocker or FileVault full-disk encryption.	Standard	It sets a mandatory technical minimum for corporate devices.
6	Employees should avoid public unsecured Wi-Fi when travelling.	Guideline	It is recommended user behaviour and allows judgement based on circumstances.
7	Suspected breach must be reported immediately to Helpdesk extension 5555.	Procedure	It tells employees what action to take and identifies the operational reporting route.
8	Passwords must be at least 14 characters with specified character types.	Standard	It defines a mandatory, measurable password requirement.

1.3 Simple Documentation Hierarchy



The hierarchy is intended to stop technical instructions from being placed inside high-level policy documents while still keeping the documents connected.

Evidence Bundle 2 — Acceptable Use Policy

NexusTech Solutions — Acceptable Use Policy

Document control	Details
Title	Acceptable Use Policy
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	18 September 2026
Review Date	18 September 2027

2.1 Purpose

This policy sets the rules for using NexusTech company-provided devices, systems and networks. It is intended to reduce malware, information security and compliance risks while allowing employees to use company resources for legitimate work.

2.2 Scope

The policy applies to all NexusTech employees, contractors, interns and other authorised users who access company devices, systems, applications, networks or information.

2.3 Acceptable Use

- Users must use company systems primarily for authorised business activities and in a way that supports security and the organisation's work.
- Users must protect company credentials and must not share passwords, authentication codes or access tokens with other people.
- Users must only access information and systems they are authorised to use.
- Users must follow approved security requirements for company devices, applications, networks and information.
- Users must report suspected security incidents, loss of company devices or accidental disclosure of information to the IT Helpdesk or approved security reporting channel without unnecessary delay.

2.4 Prohibited Activities

- Users must not install or download unauthorised software on company-managed devices.

- Users must not disable, bypass or interfere with security controls such as endpoint protection, encryption or access controls.
- Users must not use company systems to conduct unlawful activities, harassment, discrimination, fraud or activities that could damage NexusTech's reputation.
- Users must not attempt to gain unauthorised access to systems, accounts, networks or information.
- Users must not use company resources to distribute malware, malicious code or unauthorised content.
- Users must not store or transfer company-sensitive information through personal cloud storage or other unapproved services.

2.5 Reasonable Personal Use

Limited personal use is allowed when it is lawful, does not interfere with work, does not create a security or compliance risk, does not consume excessive company resources and does not involve prohibited activities. NexusTech may restrict or stop personal use where it creates a business or security concern.

2.6 Roles and Responsibilities

Role	Responsibilities
All users	Follow the policy, protect access credentials, use systems responsibly and report suspected incidents or violations.
Managers	Ensure team members understand the policy and support appropriate access and compliance decisions.
IT/Security	Maintain relevant controls, provide guidance, monitor for policy violations and support incident handling.
HR	Support employee communication and appropriate disciplinary processes where policy violations involve employee conduct.

2.7 Compliance and Enforcement

NexusTech may monitor use of company systems where permitted by law and organisational rules. Violations may result in removal or restriction of access, additional training, disciplinary action or other appropriate action depending on the nature and seriousness of the violation. Serious security concerns may be escalated to management, HR and the Information Security function.

2.8 Exceptions

Exceptions must be documented, justified by a business need, risk-assessed and approved by the Information Security Manager and the relevant business owner. Exceptions should have an expiry or review date. Emergency exceptions may be approved temporarily by the appropriate manager and must be documented and reviewed afterwards.

2.9 Approval and Review

The policy is owned by the Information Security Manager and approved by Marcus Vance, CEO. It will be reviewed at least annually and earlier when there is a significant technology, regulatory, business or security change.

Evidence Bundle 3 — User Access Request Procedure

3.1 Purpose and Scope

This procedure gives Helpdesk a consistent process for requesting, approving and provisioning access to NexusTech systems. It applies to new access, changes to existing access and access removal.

3.2 Prerequisites

The technician should have access to the approved ticketing/workflow system and the authorised account-provisioning process. Requests must identify the user, system/application, requested role or access level, business reason, manager and, where applicable, data owner.

3.3 Procedure

- 1. Receive the request:** Accept access requests only through the approved ticket or workflow. Do not provision access from an informal email, chat message or verbal request alone.
- 2. Check the request:** Confirm that the ticket identifies the user, system, requested access, business reason and required approvers.
- 3. Verify approval:** Confirm the user's manager has approved the request. Where sensitive data or a business-owned application is involved, verify data-owner/application-owner approval as required.
- 4. Check for completeness:** If required approval or information is missing, return the ticket to the requester. Do not provision access until the required approval is recorded.
- 5. Confirm the appropriate role:** Select the approved role or permission set that matches the user's job responsibilities. Apply least privilege and avoid granting broader access simply for convenience.
- 6. Create or update the account:** Using the approved account-management process, create the account or update the existing account at a high level. Apply the approved role and required security controls.
- 7. Verify access:** Check that the account has only the approved permissions and that the request has been implemented as recorded in the ticket.
- 8. Notify the user and manager:** Notify the user that access has been provisioned and, where appropriate, notify the manager. Do not send passwords or sensitive credentials through the ticket.
- 9. Capture evidence:** Record the approval, implemented role, date, technician and relevant provisioning evidence in the ticket or approved system.
- 10. Close the ticket:** Confirm the request is complete, attach or reference the required evidence, record any relevant notes and close the ticket.

3.4 Emergency or Exceptional Requests

For a genuine emergency, the authorised emergency access route may be used with the relevant manager/security approval. The technician must record why normal approval could not be followed, what access was granted and when it should be removed or reviewed. Emergency access should be reviewed after the event.

3.5 Record Retention and Audit Trail

Access requests, approvals, provisioning evidence, changes and closure records must remain in the approved ticketing/workflow system according to NexusTech's record-retention requirements. The audit trail should be sufficient to show who requested, approved, implemented and closed the access request.

Evidence Bundle 4 — Communication and Training Plan

Because the AUP is new, the rollout should give people a chance to understand what changed rather than only sending them the document.

Audience	Key message	Channel	Owner	Timing	Acknowledgement	Success measure
General employees	What is acceptable use, what is prohibited, and how to report a suspected incident.	All-hands briefing, email, intranet and mandatory learning module.	Information Security + HR	Week 1 announcement; training in Week 2.	Electronic AUP attestation after training.	≥95% training completion; ≥95% acknowledgement.
IT / Helpdesk	Access and device rules must be followed through approved processes; informal requests are not enough.	Technical briefing, procedure walkthrough and team meeting.	Information Security Manager + IT Manager	Week 1-2.	Attestation plus short knowledge check.	≥95% knowledge-check pass rate; zero unapproved access requests after rollout period.
Managers	Managers are responsible for reinforcing the AUP and supporting appropriate approvals and escalation.	Manager briefing and email pack.	Information Security Manager + HR	Week 1.	Manager acknowledgement.	100% manager briefing completion; fewer repeated policy misunderstandings.
HR	Policy violations should be handled consistently and escalated through the agreed employee process.	HR briefing and reference guide.	Information Security + HR	Week 2.	HR acknowledgement.	100% HR briefing completion; documented escalation route available.

4.1 Rollout Timeline

- Day 1: CEO announcement explains why the AUP was introduced and when it becomes effective.
- Days 2-5: Publish the AUP on the intranet and send a short employee summary with reporting contacts.
- Week 2: Run mandatory training and role-specific briefings for IT, Helpdesk and managers.
- Week 2: Employees complete the knowledge check and electronic acknowledgement.
- Weeks 3-4: Information Security reviews completion, acknowledgement and knowledge-check results and follows up with outstanding users.

- After rollout: Repeated non-compliance is escalated to the user's manager and HR where appropriate; serious security issues are escalated to Information Security management.

Evidence Bundle 5 — Policy Review and Maintenance Memo

To	Information Security Steering Committee
From	Information Security Manager
Subject	Review of Acceptable Use Policy following AWS migration and personal-cloud incident
Date	18 September 2027

The AUP should be reviewed because two material changes have occurred. First, NexusTech has migrated its primary database to AWS, which changes the technology environment and introduces cloud-specific responsibilities and usage considerations. Second, an employee shared a sensitive document through a personal cloud storage account. This incident shows that the existing AUP needs to be checked against actual user behaviour and whether the rules around approved storage and information sharing are clear enough.

I recommend a short formal review involving Information Security, IT/Cloud, Legal/Compliance where relevant, HR and business/data owners. The review should examine the incident record, user feedback, monitoring or audit evidence, AWS migration changes and any recurring policy questions, then assess the related risks. Two immediate AUP updates should be considered: make it explicit that sensitive company information must only be stored or shared through approved corporate services and add a clearer requirement that cloud services used for company information must be authorised by NexusTech. The revised version should remain owned by the Information Security Manager and go to Marcus Vance, CEO, for approval. After this review, the AUP should be reviewed annually, with an early review triggered by a major technology or cloud change, a significant security incident, a material regulatory change or repeated evidence that users misunderstand a requirement.

References and Supporting Sources

- International Cybersecurity and Digital Forensics Academy (ICDFA). GRC102 Week 2 Practical Laboratory — Developing Security Policies and Procedures.
- International Organization for Standardization (ISO). ISO/IEC 27001:2022 — Information security management systems — Requirements.
- International Organization for Standardization (ISO). ISO/IEC 27002 — Information security controls guidance.
- National Institute of Standards and Technology (NIST). Cybersecurity Framework (CSF) 2.0.
- American Institute of Certified Public Accountants (AICPA). SOC 2 Trust Services Criteria concepts.